PRIVACY-G

2026.09

전사 개인정보 거버넌스 (개인정보 라이프사이클 관리)



보유현황, 동의이력, 파기대상,
정보주체 권리요구 처리 현황 등
전 주기를 통합관리

타이거컴퍼니 한형덕 상무

개인정보 관리환경의 변화

개인정보 활용 확대와 공급망 관리, 운영 책임 강화

활용 확대

AI·디지털 서비스·플랫폼

- AI 기술 및 대규모 데이터 활용 급증
- 수집·이용 접점 및 처리 경로 복잡화

외부 처리

클라우드·전문수탁자

- 클라우드 및 외부 수탁사 의존도 심화
- 기업 내부를 넘어 공급망 전반 점검 확대

운영 책임

경영진의 보호활동

- 경영진 중심의 실질적 거버넌스 요구
- 관리현황과 보호조치의 실효성 입증 필요

공공 전담인력 **0.7 명** (기초지자체 0.3명)

인력 한계를 극복하기 위해 전사 처리현황과 실제 조치를 한눈에 검증할 통합 관리 기반 이 시급합니다.

※ 출처: 개인정보위(2026.05.12). 공공부문 전담인력 실태조사 결과 기준.

최근 사고에서 확인한 관리 과제

공개 조사 결과를 전사 관리 관점에서 분석

골프존

개인정보위 조사·처분 (2024.05.08)

▲ **개인정보파일 식별 누락 :**
업무용 파일서버(NAS)에 보관된 대규모 개인정보파일이 관리·감독 대상 및 현황 목록에서 완전히 누락되어 방치

▲ **전사 관리 사각지대 :**
기본 시스템 외 비정형 데이터 보관 서버가 CPO 통제선에서 벗어나 있어 대규모 개인정보 유출 사고로 직결

티빙

과기정통부 조사 결과 (2026.09.04)

▲ **비활성화 계정 유출 :**
유출 범위에 비활성화 계정 1,737만 건 포함
(전체 유출 계정의 약 44%에 달함)

▲ **미이용 정보 방치 :**
현재 서비스에 이용하지 않는 과거 정보의 보유 근거와 보존 기한이 지난 정보에 대한 평상시 관리 미흡 노출

점검 과제 01 / 관리 범위

전사 관리체계에서 누락된 시스템·업무가 존재하는가?

점검 과제 02 / 보유 상태

현재 이용하지 않는 휴면·과거 정보의 보존 근거를 아는가?

※ 과거 정보 보유 자체가 위법을 뜻하지 않으며, 공개 조사 결과에서 도출한 실무 점검 시사점입니다.

개인정보 관리의 배경

수집부터 파기까지 이어지는 리스크

사고 여부와 관계없이 평상시에 상시 점검해야 하는 기준

수집·동의

수집 목적과 항목 적정성

법적 근거 및 필수·선택 동의

적용 버전 및 배포이력

리스크: 근거·범위 불일치 수집

이용·제공

이용 목적·범위 준수 여부

제3자 제공 및 위탁 관계

국외이전 및 변경 내역 추적

리스크: 실제 처리와 대장 괴리

보유·파기

보유기간 및 상태 모니터링

예외 법령 보존 근거 관리

파기 대상 도출 및 결과 증적

리스크: 기한 경과 미파기 방치

권리요구

열람·정정·삭제 요구 대응

처리정지 및 철회 적용

담당자 배정 및 진행상태 확인

리스크: 요청과 실제 조치 불일치

리스크는 수집 순간부터 시작됩니다. 각 단계의 처리기준과 현재 상태, 실제 처리결과를 단일 체계로 통합 관리해야 합니다.

사후대응에서 사전예방으로의 전환

예방 중심 개인정보 관리체계 전환 계획 (개인정보위 2026.05.12)

AS-IS

사후 대응 중심

사고 발생 후 조사 · 제재 · 수습

→

TO-BE

사전 예방 체계

잠재 위험 사전 식별 · 설계 단계 보호 · 상시 점검

1. 위험 기반 점검

고위험 분야 우선 점검 및 외부 수탁사 공급망까지 관리 확대

2. 설계 단계 보호

서비스 기획 및 시스템 설계 단계부터 보호 요건 선제 반영

3. 선제적 보호 투자

법정 최소 기준을 뛰어넘는 실효적 안전조치 및 시스템 구축

4. 경영진 책임성

보호 활동 내역 투명 공개 및 최고 책임자의 이행 책임 유도

※ 위험을 관리하려면 먼저 '어떤 개인정보를 어디서 어떻게 처리하는지' 정확히 알아야 합니다.

기술적 보호와 관리적 보호의 상호작용

처리기준과 책임, 실제 운영 상태를 함께 점검해야 완전한 보안 달성

구분	기술적 보호조치	관리적 보호조치 (PIL-M 영역)
관리 초점	접근·저장·전송 과정의 안전성 및 이상행위 탐지	**처리기준·책임·절차와 현재 관리 상태 점검**
주요 수단	접근통제, DB 암호화, 보안관제, 취약점 진단	**동의이력, 보유현황, 처리관계, 파기·권리요구 관리**
지속 확인	보안 솔루션 적용 상태, 비정상 접근 징후 감시	**보유 근거와 기간의 적정성, 실제 조치와 완료 결과 대조**

기술적 방어막이 있어도 처리근거가 없거나 기한이 지난 정보를 방치하면 규제 위반입니다. 처리기준과 책임을 연결해야 합니다.

분산된 업무를 통합 기준으로 연결해야 하는 이유

하나의 개인정보를 기준으로 수집 근거부터 실제 처리결과까지 연계

관리 업무	분산된 관리 방식 (AS-IS)	함께 확인할 공통 기준 (TO-BE)
보유현황	엑셀·수기 관리대장 파편화	시스템 · 파일 · 담당부서 표준 기준화
동의서·처리방침	부서별 문서 보관 및 개별 시스템 고립	적용 버전 관리 및 실제 동의이력 연결
제공·위탁·이전	각 부서의 개별 계약대장 관리 단절	목적 · 대상 · 처리관계 · 변경이력 통합
파기·권리요구	단방향 요청 전달 및 수동 결과 재확인	담당자 · 진행상태 · 원천 처리결과 자동 검증

공통 기준과 전 주기 이력이 있어야 업무 사이의 사각지대와 관리 누락을 즉시 식별할 수 있습니다.

개인정보 라이프사이클 통합관리, PIL-M

동의정보를 기반으로 개인정보 라이프사이클 전 주기의 업무와 이력을 연결

수집·동의 관리

수집목적·항목·보유기간 세트화, 동의서 버전과 실제 동의이력 매핑

이용·제공·위탁 관리

외부 처리관계 및 계약 변경이력, 이용통지 및 재동의 주기 일괄 관리



보유·파기 관리

보유상태·기한 모니터링, 파기 대상 검토 승인 및 원천 파기결과 대조

권리보장 관리

열람·정정·삭제·철회 요청 접수, 담당자 지정, 결과 회신 및 증적 보관

단일 공통 기준

시스템 · 개인정보파일
담당부서 · 동의정보

단일 소프트웨어(PIL-M) 도입만으로 전사 개인정보 처리 전 과정을 실시간으로 조망하고 통제합니다.

원문 비저장 기반의 안전한 운영 구조

개인정보 원문은 기존 원천시스템에 유지하고, 관리정보와 이력만 PIL-M에서 통제

PIL-M (관리 허브)

관리정보 및 이력 통합 통제

- **연계토큰 관리:** 식별 불가 토큰 및 메타데이터 보관
- **이력 아카이빙:** 동의·파기·권리요구 처리이력 및 증적 기록
- **통합 대시보드:** CPO 및 개인정보 취급자의 통합 현황 조회

안전한 API 연계

요청 및 결과 회신

원천시스템 (기존 인프라)

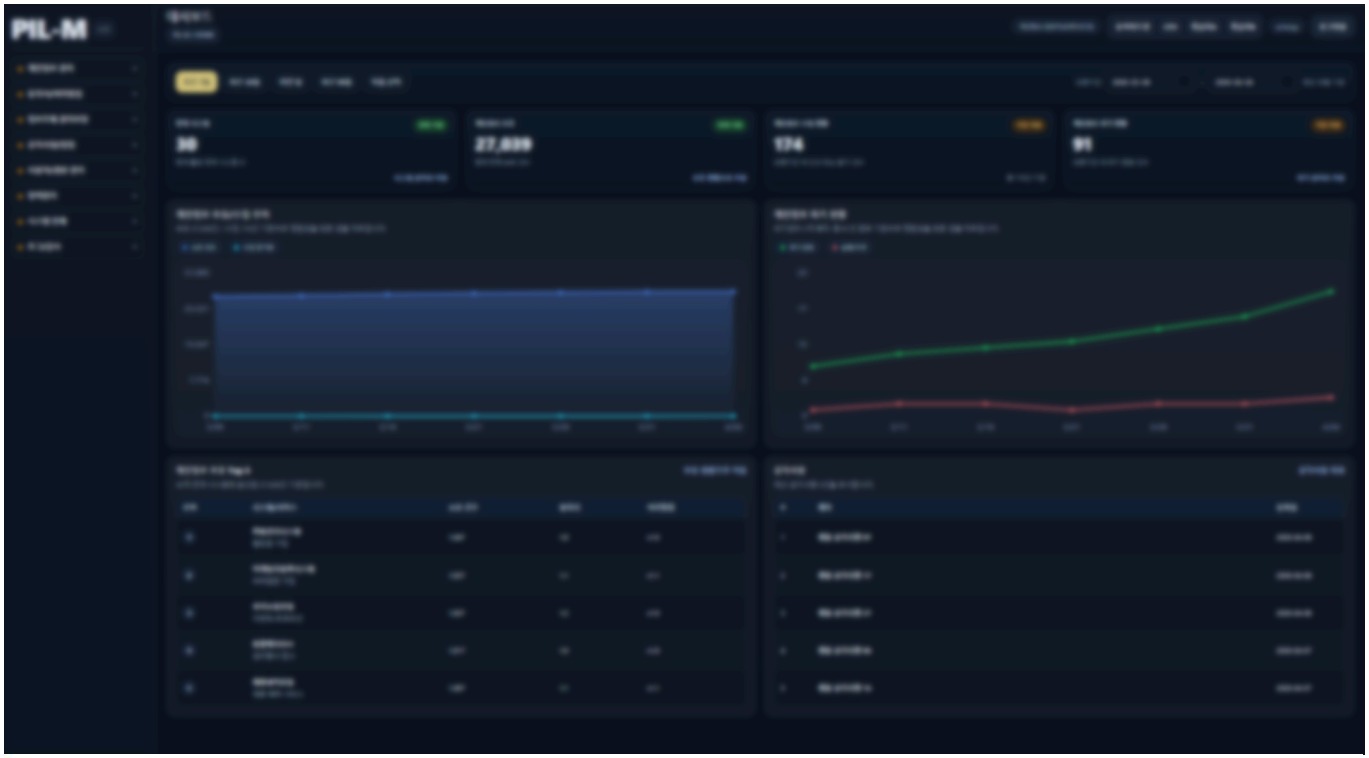
개인정보 원문 보관 및 실제 처리

- **원천 DB 보관:** 회원·CRM·ERP 시스템에 원본 데이터 보존
- **실제 액션 수행:** 데이터 조회, 수정, 정정, 물리적 파기 실행
- **결과 반환:** 작업 처리일시 및 상태 코드를 PIL-M에 회신

개인정보 원문을 PIL-M에 추가 저장하지 않으므로 데이터 중복 구축 및 2차 유출 위험을 원천 차단합니다.

보유현황이 모든 관리업무의 기준점

시스템·개인정보파일·담당부서를 공통 기준으로 관리하는 종합 대시보드



도출된 보유현황 데이터베이스를 동의·제공·위탁·파기 업무의 절대적 단일 기준으로 활용합니다.

관리 대상 식별

시스템 & 파일

전사 연계 시스템 30개 및
개인정보파일별 보유 현황 식별

관리 책임 명확화

부서 & 담당자

취급 부서와 실무 담당자를 지정하여
책임 소재 및 이행 상태 확정

실시간 처리 추적

보유 · 파기 · 권리요구

수집 증감, 만료 도래, 파기 진척도,
권리요구 접수·처리 실시간 집계

동의서·처리방침의 기준과 이력 관리

현재 유효한 문서뿐만 아니라 고객 수집 당시 적용된 과거 문서까지 즉시 검증

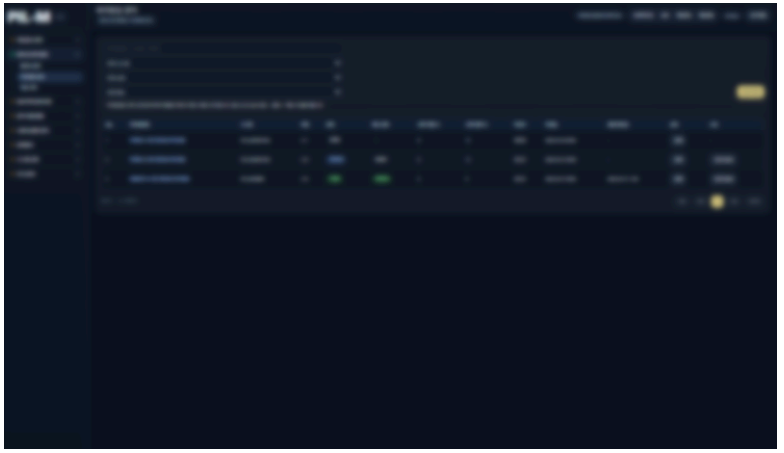
동의서 관리

- **구성요소 표준 세트화:** 목적, 수집항목, 보유기간 템플릿화
- **버전 및 배포이력:** 개정 내역과 시스템 배포 시점을 시스템적 기록
- **개별 동의이력 매핑:** 고객이 실제 체크한 당시의 동의서 버전 연결



처리방침 관리

- **법정 필수항목 구조화:** 조항별 현행본 및 이전 버전 비교 대조
- **변경이력 추적:** 작성일, 결재일, 공고일, 시행일 등 투명한 타임라인
- **대외 공개 현행화:** 법령 개정 및 실무 변동 시 방침 반영 누락 차단



파기 검토부터 원천 완료 확인까지

보유기간과 예외 보존 근거를 시스템에서 검토하고, 원천 처리결과로 종결

01 도출 단계

검토대상 확인

동의 만료, 회원 탈퇴 등 기초 파기 대상 데이터 자동 집계

02 심사 단계

근거 검토·승인

상법·전자상거래법 등 예외적 보존 법령 사유 확인 및 관리자 승인

03 실행 단계

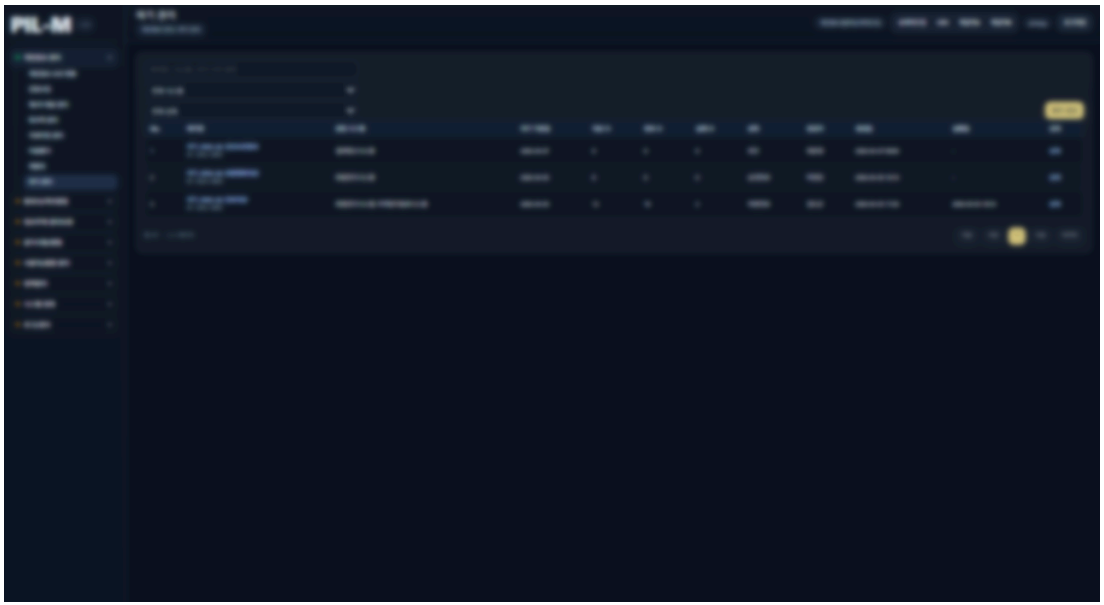
원천 파기요청

승인된 대상 정보를 원천시스템에 안전한 API로 파기 처리 지시

04 완료 단계

완료 대조·증적

처리일시, 항목, 결과코드, 증적 파일을 수신하여 종결 확인



실제 물리적 파기는 원천시스템에서 수행되며, PIL-M은 파기 프로세스의 정당성과 완료 증적을 무결하게 보관합니다.

정보주체 권리요구의 접수와 원천 연동 처리

고객의 열람·정정·삭제 요청을 원천시스템의 조치와 결과 회신까지 일원화



정보주체 (권리보장 포털)

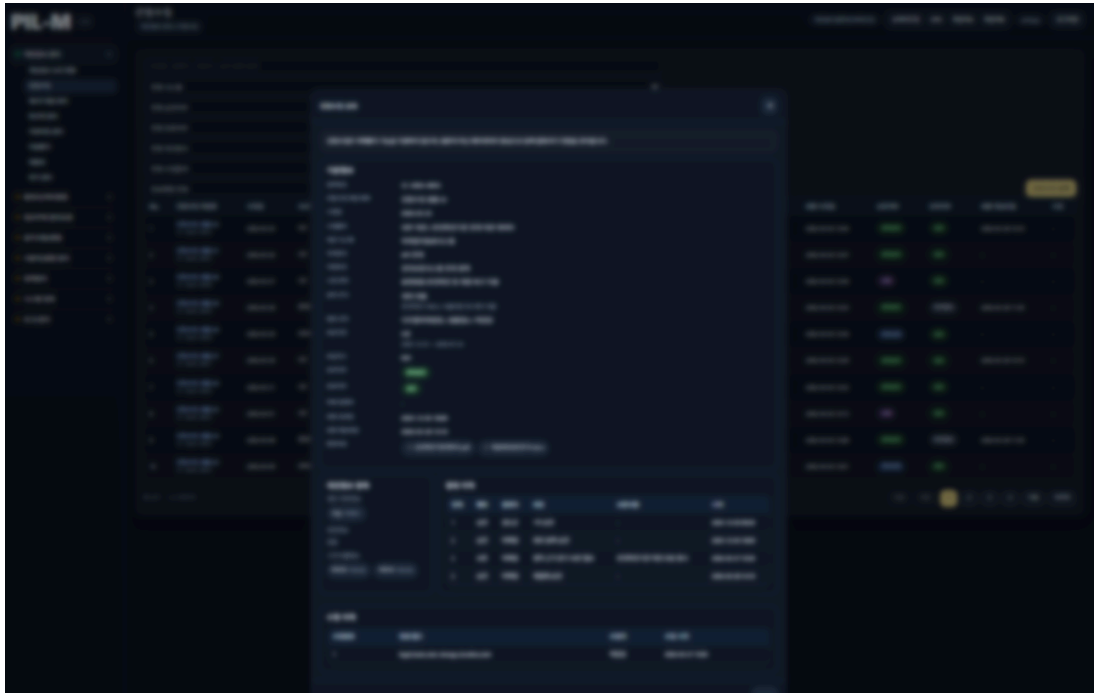
내 정보 보유 현황 및 권리행사

- 보유 시스템 및 서비스별 개인정보 보유 내역 확인
- 열람 · 정정 · 삭제 요구 간편 신청
- 처리정지 및 동의철회 요청, 진행상태 실시간 조회

단순 민원 접수에 그치지 않고, 원천 DB 데이터의 실제 정정·삭제 완료까지 시스템적으로 종결 처리합니다.

조직 밖의 개인정보 처리관계 관리

담당자나 계약관계가 변경되어도 처리 목적·대상·이력을 투명하게 파악



간접수집 관리

수집 출처와 경로, 법적 처리 근거, 보유기간 메타데이터 및 등록 결재선 추적

제3자 제공 관리

제공 목적, 제공받는 자, 제공 항목 대장화 및 동의 획득 이력 상시 대조

위·수탁 관리

수탁업체 정보, 위탁업무 범위, 수탁자 정기 실태점검 내역 및 교육 이력 관리

국외이전 관리

이전 국가, 이전받는 법인, 이전 일시, 법적 보호장치 구비 현황 및 변경이력 추적

사내 시스템 외부로 나가는 모든 데이터 흐름의 시작과 끝을 기록하여 공급망 전반의 안전성을 확보합니다.

전사 개인정보 거버넌스의 상시 운영 기준

정확한 보유현황과 지속적인 처리과정 점검이 사전예방의 출발점입니다

점검 주제	확인할 관리현황 (PIL-M)	이어지는 능동적 관리 조치
보유현황	시스템 · 파일 · 담당부서 현황	**누락된 신규 시스템 및 변경사항 상시 갱신**
동의·처리방침	적용 버전별 동의이력 매핑	**실제 수집 항목과 처리방침 대조 및 적법성 검증**
파기대상	보유기간 만료 및 보존 근거	**원천 파기 미완료 건 독촉 및 최종 증적 수동 대조**
권리요구	담당자 배정 및 실시간 진행상태	**원천 조치 결과 확인 후 법정 기한 내 완료 통지**

CPO(개인정보보호책임자)와 일선 업무 담당자가 단일 화면에서 현재 상태, 처리이력, 조치결과를 공동 확인해야 합니다.

전사 개인정보 거버넌스 관련 법령 체계

개정 개인정보 보호법(국외이전·처리방침 평가·전송요구권 등) 및 신용정보법 최신 컴플라이언스 기준 반영

최신 개정 법령 및 PIL-M 준거 기준

개인정보 보호법

- 제15조 (개인정보의 수집·이용)
- 제16조 (개인정보의 수집 제한)
- 제20조 (수집 출처 등 통지)
- 제20조의 2 (이용·제공 내역 통지)
- 제21조 (개인정보의 파기)
- 제22조·제22조의 2 (동의 방법·아동 보호)
- 제26조 (업무위탁에 따른 처리 제한·감독)
- 제28조의 8 (개인정보의 국외 이전) 신설
- 제30조 (개인정보 처리방침의 수립·공개)
- 제35조·제35조의 2 (열람 및 전송요구권) 신설
- 제36조·제37조 (정정·삭제 및 처리정지)
- 제37조의 2 (자동화된 결정에 대한 권리) 신설
- 제38조 (권리행사의 방법 및 절차)

개인정보 보호법 시행령

- 제15조의 2 (수집 출처 통지대상·방법)
- 제15조의 3 (이용·제공 내역의 통지)
- 제16조 (개인정보의 파기 방법 등)
- 제17조 (동의를 받는 방법 등)
- 제29조의 8 (국외 이전 기준 및 절차) 신설
- 제31조 (처리방침의 내용 및 공개방법)
- 제31조의 2 (처리방침의 평가 등) 신설
- 제41조·제42조 (열람절차 및 열람 제한·거절)
- 제43조·제44조 (정정·삭제 및 처리정지)
- 제44조의 2 (자동화 결정 거부 기준·절차) 신설
- 제48조 (열람요구 지원시스템 구축 등)

신용정보법

- 제15조 (신용정보 수집·조사 및 처리원칙)
- 제20조 (관리책임 명확화·기록 보존)
- 제20조의 2 (개인신용정보 보유기간 등)
- 제32조 (제공·활용에 대한 동의)
- 제33조의 2 (개인신용정보 전송요구권)
- 제34조의 2 (제공·활용 동의의 원칙)
- 제35조 (이용 및 제공사실의 조회)
- 제37조 (개인신용정보 제공동의 철회권)
- 제38조 (열람 및 정정청구 등)
- 제38조의 3 (개인신용정보 삭제 요구)
- 제39조의 3 (권리행사의 방법 및 절차)

PIL-M은 국외이전·처리방침 평가 등 최신 개정 법령 요건을 완벽히 충족하며, 전 주기 컴플라이언스 기준을 통합 통제합니다.

전사 개인정보 거버넌스 기반의 사전예방

정확한 보유현황, 지속적인 처리과정 관리

사전예방의 출발점입니다



개인정보 라이프사이클 통합관리 시스템

타이거컴퍼니 제품 문의 한형덕 상무 010-8868-5625 / hdhan@tigrison.com